

منصة شاهين الرقمية
سياسة تكامل الأنظمة والربط الإلكتروني (API)
نوفمبر 2025



Internal

DO NOT COPY

الاسم المسجل : شركة الوثيقة الماسية لوساطة التأمين
المركز الرئيسي : طريق الشمامة , الربيع , الرياض
مسؤول المستند : مدير إدارة الجودة والتطوير

المحتويات	
1	المقدمة
2	الهدف من السياسة
3	تعريف
4	نطاق تطبيق السياسة
5	القطاعات والإدارات ذات العلاقة
6	الكيانات ذات العلاقة
7	قواعد عامة
8	مسؤولية السياسة
9	التعاميم والتعليمات ذات العلاقة
10	حفظ السياسة
11	مخالفة السياسة



إدارة الجودة والتطوير Quality & Development Management

المادة (1): يحتوي هذا المستند على المعلومات المتعلقة بمنصة شاهين الرقمية ولا يجوز استخدام أو نسخ هذا المستند أو المعلومات التي يحتوي عليها كاملة أو جزءاً منها أو كشفه إلى الغير ما لم تقدم شركة الوثيقة الماسية (دايموند) موافقتها الكتابية على ذلك. لا يجوز تعديل أو حذف هذا التصريح المقيد في أي حالة من هذا المستند.

المادة (2): في حال وجود اختلاف بين النص العربي والإنجليزي فإن السيادة تكون للنص العربي.



معلومات السياسة				
سياسة تكامل الأنظمة والربط الإلكتروني (API)			عنوان السياسة	
مُستحدثة			حالة السياسة	
لا يوجد			عنوان السياسة السابقة	
لا يوجد			تاريخ السياسة السابقة	
بعد مُرور سنتين من تاريخ اعتماد السياسة أو عند الضرورة			تاريخ المراجعة القادمة	
1SP0005			رقم المستند	
منصة شاهين الرقمية			مالك السياسة	
إدارة الجودة والتطوير			إعدت بواسطة	
مسؤولو القطاعات والإدارات الذين راجعوا السياسة ووافقوا عليها				
التوقيع	التاريخ	الأسم	الوظيفة	الإدارة
	2025-12-28	تركي عبدالله العبدلي	مدير إدارة الإلتزام والامتثال	الإدارة الرقابية
	2025-11-26	عنه: هاني هاشم	مدير إدارة الجودة والتطوير	رئيس مراجعة السياسات
اعتماد السياسة				
	2025-12-28	بدر سعد الشايح	العضو المنتدب	الإدارة العليا



إدارة الجودة والتطوير
Quality & Development Management

1. المقدمة:

1.1 تُعد سياسة سياسة تكامل الأنظمة والربط الإلكتروني (API) جزءاً أساسياً في تنظيم آلية ربط المنصة الرقمية لشركة الوساطة بالأنظمة الداخلية والخارجية عبر واجهات برمجة التطبيقات (APIs) ، لضمان سلامة تدفق البيانات وتطبيق أعلى معايير الأمن السيبراني والحوكمة التقنية.

2. الهدف من السياسة:

2.1 تثق شركة الوثيقة الماسية لوساطة التأمين (ويشار إليها فيما يلي بـ "شاهين") في أن الهدف من هذه السياسة هو تنظيم التكامل الإلكتروني بين المنصة الرقمية وأنظمة الجهات الداخلية والخارجية عبر واجهات برمجة التطبيقات (APIs)، بما يضمن سلامة تبادل البيانات ودقتها، وحماية المعلومات من الوصول غير المصرح به، واستمرارية الخدمات الرقمية وفق متطلبات الأمن السيبراني والحوكمة التقنية وتعليمات الجهات التنظيمية ذات العلاقة.

3. تعاريف:

- 3.1 منصة شاهين (Shahin Platform): المنصة الرقمية التابعة للشركة، والمتخصصة في ربط المنصة كوسيط تأميني بشركات التأمين لتسهيل عمليات الإصدار والتجديد وإدارة العملاء إلكترونياً.
- 3.2 واجهة برمجة التطبيقات (API): مجموعة من القواعد والتعليمات التي تسمح بتبادل البيانات بين نظامين أو أكثر بطريقة آمنة ومنظمة.
- 3.3 بوابة الربط (API Gateway): منصة مركزية تُستخدم للتحكم في عمليات الاتصال، إدارة المفاتيح، وتسجيل الطلبات.
- 3.4 مفتاح الوصول (API Key): رمز فريد يُستخدم للمصادقة على هوية النظام أو الجهة المتصلة بالمنصة الرقمية.
- 3.5 التكامل (Integration): العملية التقنية التي تتيح تبادل المعلومات أو تنفيذ المهام بين أنظمة مختلفة بشكل مترابط.
- 3.6 البيانات الحساسة (Sensitive Data): أي بيانات مالية أو تأمينية أو شخصية يمكن أن يؤدي تسريبها إلى ضرر قانوني أو تشغيلي للمنصة أو عملائها.
- 3.7 الجهة الخارجية (Third Party): أي شركة تأمين أو مزود خدمة خارجي متصل إلكترونياً بمنصة شاهين.
- 3.8 خطة استمرارية الأعمال (BCP): الإجراءات والتدابير التي تضمن استمرار الأنظمة الحيوية أثناء الأزمات أو الأعطال التقنية.

4. نطاق تطبيق السياسة :

- 4.1 تُطبق هذه السياسة على
 - 4.1.1 الأنظمة الداخلية والخارجية المربوطة بالمنصة الرقمية.
 - 4.1.2 مشاريع التكامل الإلكتروني مع شركات التأمين أو الجهات الحكومية أو مزودي الخدمات التقنية.
 - 4.1.3 موظفي إدارة تقنية المعلومات، الأمن السيبراني، والجودة والتطوير عند مراجعة أو اعتماد أي عملية ربط.
 - 4.1.4 أي طرف خارجي يُمنح حق الوصول إلى أنظمة الشركة أو قواعد بياناتها عبر واجهات APIs.

5. القطاعات والإدارات ذات العلاقة:

- 5.1 إدارة تقنية المعلومات .
- 5.2 قسم الأمن السيبراني.
- 5.3 إدارة الجودة والتطوير .

6. الكيانات ذات العلاقة:

- 6.1 شركات التأمين المتكاملة إلكترونياً مع المنصة.
- 6.2 الهيئة الوطنية للأمن السيبراني (NCA).
- 6.3 الهيئة السعودية للبيانات والذكاء الاصطناعي (SDAIA).
- 6.4 هيئة التأمين.
- 6.5 مزودو الخدمات التقنية المعتمدون لدى الشركة.

7. قواعد عامة:

7.1 الالتزام العام:

- 7.1.1 تُعد واجهات برمجة التطبيقات (APIs) الوسيلة الرسمية والوحيدة لتبادل البيانات بين المنصة الرقمية والأنظمة الداخلية والخارجية، ويُحظر إنشاء أو استخدام أي وسيلة ربط غير معتمدة.
- 7.1.2 تُدار جميع عمليات التكامل الإلكتروني بإشراف إدارة تقنية المعلومات، وبالتنسيق مع الأمن السيبراني لضمان تطبيق معايير السرية والتكامل والتوافر (CIA).
- 7.1.3 يجب أن يلتزم كل ربط إلكتروني بمعايير الأمان والاتصال الصادرة عن الجهات الرقابية (هيئة التأمين، الهيئة الوطنية للأمن السيبراني، هيئة البيانات والذكاء الاصطناعي).
- 7.1.4 يُلزم الفريق الفني بتوثيق مسار تدفق البيانات (Data Flow Diagram) لجميع الواجهات، على أن يتضمن الأنظمة المشاركة، اتجاه البيانات، وطريقة المصادقة المستخدمة.
- 7.1.5 يُلزم الفريق الفني أيضًا بتحديث مخطط تدفق البيانات والبنية الشبكية (Network Topology) بعد كل تعديل تشغيلي أو توسعة في الربط، لضمان التحكم الكامل في الاتصالات الخارجية واستمرارية المراقبة المركزية.
- 7.1.6 تُراجع جميع عمليات الربط بشكل نصف سنوي للتأكد من استمرار صلاحيتها، توافقها مع المعايير الأمنية، واستقرار الأداء التشغيلي.
- 7.1.7 تُراجع وثائق واجهات الربط (API Documentation) مرتين سنويًا أو فور إجراء أي تعديل جوهري في بنية النظام لضمان التوافق الفني والتشريعي.

7.2 إنشاء وتوثيق واجهات الربط

- 7.2.1 يجب أن تُسجل جميع واجهات الربط في سجل رسمي يتضمن: اسم الجهة أو النظام المتكامل، الغرض من الربط، نطاق البيانات، مستوى الحساسية، نوع المصادقة، والمطور المسؤول.
- 7.2.2 يُمنع إطلاق أي واجهة جديدة قبل اعتمادها من إدارة تقنية المعلومات ومسؤول الأمن السيبراني وفقًا لنموذج اعتماد التكامل (API Approval Form).
- 7.2.3 تُطبق آلية تقييم موحدة (Version Control) لتتبع الإصدارات وضمان إمكانية الرجوع إلى الإصدار السابق عند الحاجة.
- 7.2.4 يجب أن يخضع كل ربط جديد لاختبارات قبول الأداء (Integration Testing) واختبارات الأمان (Security Testing) قبل الانتقال إلى بيئة الإنتاج.
- 7.2.5 تُحفظ جميع وثائق التكامل في نظام إدارة الوثائق التقنية مع تحديثها عند أي تعديل أو تحسين في بنية الربط.
- 7.2.6 يُحتفظ بسجل تاريخي للإصدارات (Version History) لجميع الواجهات لتسهيل التتبع والاسترجاع عند الحاجة.

7.3 أمن الربط الإلكتروني

- 7.3.1 تُشفّر جميع البيانات المتبادلة بين الأنظمة باستخدام بروتوكولات آمنة (TLS 1.2 أو أعلى) ويُحظر أي اتصالات عبر بروتوكولات غير مشفرة (HTTP / FTP).
- 7.3.2 تُطبق آلية مصادقة مزدوجة (Two-Factor Authentication) على واجهات الربط الحرجة، مع تحديد المفاتيح (API Keys) لكل جهة خارجية على نحو مستقل.
- 7.3.3 يُمنع مشاركة مفاتيح الوصول بين أكثر من نظام أو جهة، وتُجدد المفاتيح تلقائيًا كل (90) يومًا كحد أقصى.
- 7.3.4 يُفعل نظام تتبع السجلات (Audit Logs) لتوثيق جميع محاولات الوصول، بما في ذلك المستخدم، التوقيت، وعنوان المصدر (IP Address).
- 7.3.5 تُطبق ضوابط الحماية من هجمات الحرمان من الخدمة (DoS / DDoS) عبر تحديد عدد الطلبات المسموح بها (Rate Limiting) لكل واجهة.
- 7.3.6 تُدار جميع عمليات الاتصال من خلال بوابة مركزية (API Gateway) تتيح التحكم في الوصول، إدارة المفاتيح، ومراقبة الأداء الأمني بشكل موحد.
- 7.3.7 تُخضع واجهات الربط الحرجة لاختبارات اختراق نصف سنوية (Penetration Tests) وفق معايير OWASP API Security Testing، وتُوثق نتائجها في سجل الأمن السيبراني.

7.4 التحقق من صحة البيانات المتبادلة



- 7.4.1 يجب أن تتضمن جميع واجهات الربط آلية تحقق من سلامة البيانات (Data Validation) قبل قبولها أو إدخالها إلى النظام الداخلي.
- 7.4.2 تُرفض تلقائيًا أي بيانات غير متوافقة مع البنية المحددة (Schema Validation Error) ويُسجل الحدث في السجلات الأمنية.
- 7.4.3 تُستخدم آليات توقيع رقمي (Digital Signature) للتحقق من مصدر البيانات المرسله وضمان عدم تعديلها أثناء النقل.
- 7.4.4 تُجرى مراجعات فصلية لعينات من البيانات المتبادلة للتأكد من دقة التكامل وفعالية الضوابط الأمنية.
- 7.4.5 في حال اكتشاف تباين أو خلل في تدفق البيانات، تُوقف عملية الربط مؤقتًا لحين تصحيح الخلل واعتماد الإجراء التصحيحي من إدارة تقنية المعلومات.
- 7.4.6 يجب توثيق جميع سيناريوهات الأخطاء (Error Handling Scenarios) وخطط الاستجابة لتفادي فقد البيانات أو تضاربها أثناء عمليات الربط.
- 7.5 إدارة العلاقة مع الجهات الخارجية
- 7.5.1 لا يجوز لأي جهة خارجية الوصول إلى واجهات الربط دون توقيع اتفاقية مستوى الخدمة (SLA) واتفاقية حماية البيانات (NDA / BAA) الموقعه رسميًا مع الشركة.
- 7.5.2 يُلزم جميع الشركاء الخارجيين باستكمال تقييم مخاطر أمنية (Third-Party Security Risk Assessment) قبل التفعيل، لضمان توافقهم مع معايير أمن المعلومات المعتمدة.
- 7.5.3 تُصنف الجهات الخارجية حسب مستوى الخطورة (حرجة – عالية – متوسطة – منخفضة)، وتُحدد ضوابط الوصول بناءً على هذا التصنيف.
- 7.5.4 يُلزم الشركاء الخارجيون بإخطار إدارة تقنية المعلومات قبل إجراء أي تعديل في نظامهم المتصل بالمنصة، ليُعاد اختبار التكامل قبل إعادة التشغيل.
- 7.5.5 عند انتهاء التعاقد أو إنهاء الربط، تُلغى جميع المفاتيح والصلاحيات خلال 24 ساعة وتوثق عملية الإلغاء في سجل الربط الإلكتروني.
- 7.5.6 تُراجع اتفاقيات الربط الفني بشكل سنوي للتأكد من مطابقتها للتغيرات في البنية التقنية أو التشريعات التنظيمية.
- 7.6 المراقبة والتحليل والتقارير
- 7.6.1 تُفعل أدوات المراقبة الفورية (Real-Time Monitoring) لجميع الواجهات لتتبع معدلات الطلب، الأخطاء، وأداء الشبكة.
- 7.6.2 تُرسل تنبيهات تلقائية لمسؤولي التقنية عند تجاوز حدود الاستخدام أو توقف الخدمة لأكثر من 10 دقائق.
- 7.6.3 تُحلل السجلات التشغيلية أسبوعيًا لاكتشاف الأنماط غير الطبيعية أو محاولات الوصول غير المصرح بها.
- 7.6.4 تُعد تقارير شهرية تشمل عدد العمليات، نسب الأخطاء، وأزمة الاستجابة، وتُرفع إلى مدير تقنية المعلومات والأمن السيبراني.
- 7.6.5 تُراجع نتائج المراقبة ربع سنويًا ضمن اجتماعات الحوكمة التقنية لتحديد فرص التحسين وتعزيز الضوابط الأمنية.
- 7.7 استمرارية الخدمة والتعافي
- 7.7.1 يجب أن تُدمج عمليات الربط الإلكتروني ضمن خطة استمرارية الأعمال (BCP) لضمان استمرار تبادل البيانات في حال انقطاع الخدمة.
- 7.7.2 تُنفذ اختبارات محاكاة نصف سنوية لقياس قدرة المنصة على استعادة الاتصال خلال الزمن المستهدف (RTO).
- 7.7.3 تُحفظ نسخ احتياطية محدثة من إعدادات الربط ومفاتيح الوصول في موقع آمن ومشفر.
- 7.7.4 عند فشل أي اختبار اتصال رئيسي، تُعد إدارة تقنية المعلومات تقريرًا تصحيحيًا يوضح السبب والإجراء المتخذ والمدة الزمنية للتصحيح.

8. مسؤولية السياسة.

8.1 إدارة تقنية المعلومات:

8.1.1 مسؤولون عن ضمان تطبيق جميع الضوابط الواردة في هذه السياسة عبر جميع واجهات الربط النشطة.

8.1.2 مسؤولون عن مراجعة الوثائق الفنية ونتائج الاختبارات الأمنية قبل الإطلاق.

8.2 إدارة الجودة والتطوير:

8.2.1 مسؤولون عن التأكد من تطبيق هذه السياسات من خلال التدقيق والمراجعة الدورية.

9. التعاميم والتعليمات ذات العلاقة:

9.1 لهيئة الوطنية للأمن السيبراني (NCA) — إطار ضوابط الأمن السيبراني الأساسية

9.2 الهيئة السعودية للبيانات والذكاء الاصطناعي (SDAIA) — نظام حماية البيانات الشخصية (PDPL)

9.3 هيئة التأمين السعودية — تعليمات الأمن السيبراني واستمرارية الأعمال في القطاع التأميني

10. احفظ السياسة:

10.1 تحفظ النسخة الإلكترونية الغير قابلة للنسخ من السياسة المعتمدة على نظام الموارد البشرية ويطلع عليها الإدارات ذات العلاقة.

10.2 تحفظ النسخة الورقية من السياسة المعتمدة في إدارة الجودة والتطوير حسب المدة النظامية المحددة في كتيب تقاؤم المستندات ترحل نظامياً إلى حفظ المستندات.

11. مخالفة السياسة:

11.1 يُطبق في حق المخالف لهذه السياسة ماورد في لائحة جزاءات شركة دايمنود المعتمدة.



Diamond Insurance Broker

Systems Integration and Application

Programming Interface (API) Policy

Nov 2025

Registered Name: Diamond Insurance Broker Company

Head Office: Al Thumama Road, Al Rabie District, Riyadh

Document Owner: Quality & Development Manager

Internal

DO NOT COPY

Translation

Contents	
1	Introduction.....
2	Policy Objective.....
3	Definitions.....
4	Scope of Application.....
5	Related Management and Sectors.....
6	Related Entity.....
7	General Rules.....
8	Policy Responsibility.....
9	Related Circulars and Instructions.....
10	Policy Retention.....
11	Policy Violation.....



Article (1): This document and the information it contains are related to the Shahin digital platform. They may not be used, copied, or disclosed, in whole or in part, to any third party without the prior written consent of Diamond. This restricted notice may not be altered or removed from this document under any circumstances.

Article (2): In the event of any discrepancy between the Arabic and English texts, the Arabic text shall prevail.

1. Introduction

1.1 The Systems Integration and Electronic Connectivity (API) Policy is a fundamental component in regulating how the Company's digital platform is connected to internal and external systems through Application Programming Interfaces (APIs), to ensure secure data flows and the application of the highest standards of cybersecurity and IT governance.

2. Policy Objective

2.1 Diamond Insurance Brokers Company (hereinafter referred to as "Shahin") believes that the objective of this policy is to govern electronic integration between the digital platform and internal/external entities' systems through APIs in a manner that ensures secure and accurate data exchange, protects information from unauthorized access, and maintains the continuity of digital services in accordance with cybersecurity requirements, IT governance standards, and relevant regulatory instructions.

3. Definitions

3.1 **Shahin Platform:** The Company's digital platform that operates as an insurance broker, connecting with insurance companies to facilitate electronic issuance, renewals, and customer management.

3.2 **Application Programming Interface (API):** A set of rules and specifications that enables secure and structured data exchange between two or more systems.

3.3 **API Gateway:** A centralized platform used to control connectivity operations, manage keys, and log requests.

3.4 **API Key:** A unique token used to authenticate the identity of a system or entity connecting to the digital platform.

3.5 **Integration:** The technical process that enables linked information exchange or task execution between different systems.

3.6 **Sensitive Data:** Any financial, insurance-related, or personal data whose disclosure may cause legal or operational harm to the platform or its customers.

3.7 **Third Party:** Any insurance company or external service provider electronically connected to the Shahin Platform.

3.8 **Business Continuity Plan (BCP):** Procedures and measures that ensure continuity of critical systems during crises or technical disruptions.

4. Scope of Application

4.1 This policy applies to:

4.1.1 Internal and external systems integrated with the digital platform.

4.1.2 Electronic integration initiatives with insurance companies, government entities, or technology service providers.

4.1.3 IT, Cybersecurity, and Quality & Development staff when reviewing or approving any connectivity or integration activity.

4.1.4 Any third party granted access to the Company's systems or databases through APIs.

5. Related Management and Sectors

5.1 Information Technology Department

5.2 Cybersecurity Department

5.3 Quality and Development Department

6. Related Entity

6.1 Insurance companies electronically integrated with the platform

6.2 National Cybersecurity Authority (NCA)

6.3 Saudi Data & AI Authority (SDAIA)

6.4 Insurance Authority

6.5 Company-approved technology service providers

7. General Rules

7.1 General Compliance

7.1.1 APIs shall be the official and exclusive method for data exchange between the digital platform and internal/external systems. Any unapproved integration method is strictly prohibited.

7.1.2 All electronic integration activities shall be managed under the supervision of the IT Department and in coordination with the Cybersecurity function to ensure the application of Confidentiality, Integrity, and Availability (CIA) requirements.

7.1.3 Each electronic integration shall comply with security and connectivity standards issued by the relevant regulators (Insurance Authority, NCA, and SDAIA).

7.1.4 The technical team shall document the Data Flow Diagram for all APIs, including participating systems, data direction, and the authentication method used.

7.1.5 The technical team shall update the Data Flow Diagram and Network Topology after any operational change or integration expansion to maintain full control over external connections and ensure continuous centralized monitoring.

7.1.6 All integration activities shall be reviewed semi-annually to verify validity, security compliance, and operational stability.

7.1.7 API Documentation shall be reviewed twice per year, or immediately after any material system architecture change, to ensure technical and regulatory alignment.

7.2 API Creation and Documentation

7.2.1 All APIs shall be registered in an official log that includes: integrated entity/system name, integration purpose, data scope, sensitivity level, authentication type, and the responsible developer.

7.2.2 No new API shall be released without approval from the IT Department and the CISO in accordance with the API Approval Form.

7.2.3 A unified version control mechanism shall be applied to track releases and enable rollback to a prior version when required.

7.2.4 Each new integration shall undergo Integration Testing and Security Testing prior to deployment into the production environment.

7.2.5 All integration documentation shall be stored in the approved technical document management system and updated upon any modification or enhancement.

7.2.6 A Version History shall be maintained for all APIs to facilitate traceability and retrieval when needed.

7.3 Integration Security Controls

7.3.1 All data exchanged between systems shall be encrypted using secure protocols (TLS 1.2 or higher). Any connections through unencrypted protocols (HTTP/FTP) are prohibited.

7.3.2 Two-Factor Authentication shall be enforced for critical APIs, and unique API Keys shall be assigned independently for each third party.

7.3.3 Sharing API Keys across more than one system or entity is prohibited. Keys shall be automatically rotated at least every 90 days.

7.3.4 Audit Logs shall be enabled to record all access attempts, including user identity, timestamp, and source IP address.

7.3.5 DoS/DDoS protection controls shall be applied through Rate Limiting per API.

7.3.6 All connectivity shall be managed through a centralized API Gateway that enables unified access control, key management, and security performance monitoring.

7.3.7 Critical APIs shall be subject to semi-annual penetration testing in accordance with OWASP API Security Testing standards, and results shall be documented in the cybersecurity register.

7.4 Validation of Exchanged Data

- 7.4.1 All APIs shall include Data Validation controls prior to accepting data or ingesting it into internal systems.
- 7.4.2 Any data that does not comply with the defined schema (Schema Validation Error) shall be automatically rejected, and the event shall be recorded in security logs.
- 7.4.3 Digital Signature mechanisms shall be used to validate the source of transmitted data and ensure it is not altered in transit.
- 7.4.4 Quarterly sample-based reviews of exchanged data shall be conducted to verify integration accuracy and the effectiveness of security controls.
- 7.4.5 If any discrepancy or defect in data flow is identified, the integration shall be temporarily suspended until corrective actions are implemented and formally approved by the IT Department.
- 7.4.6 All error-handling scenarios and response plans shall be documented to prevent data loss or conflicts during integration operations.
- 7.5 Third-Party Relationship Management
- 7.5.1 No third party may access APIs unless a formally executed Service Level Agreement (SLA) and a Data Protection Agreement (NDA/BAA) are in place with the Company.
- 7.5.2 All external partners shall complete a Third-Party Security Risk Assessment prior to activation to ensure alignment with the Company's information security standards.
- 7.5.3 Third parties shall be classified based on risk level (Critical – High – Medium – Low), and access controls shall be determined accordingly.
- 7.5.4 External partners shall notify the IT Department prior to making any changes to their systems connected to the platform, and integration shall be re-tested before reactivation.
- 7.5.5 Upon contract termination or integration decommissioning, all keys and privileges shall be revoked within 24 hours, and revocation shall be documented in the electronic integration log.
- 7.5.6 Technical integration agreements shall be reviewed annually to ensure alignment with changes in technical architecture or regulatory requirements.
- 7.6 Monitoring, Analytics, and Reporting
- 7.6.1 Real-time monitoring tools shall be enabled for all APIs to track request rates, error rates, and network performance.
- 7.6.2 Automated alerts shall be sent to technical owners when utilization thresholds are exceeded or when service downtime exceeds 10 minutes.
- 7.6.3 Operational logs shall be analyzed weekly to detect abnormal patterns or unauthorized access attempts.
- 7.6.4 Monthly reports shall be prepared covering transaction volumes, error rates, and response times, and submitted to the IT Director and the Cybersecurity function.
- 7.6.5 Monitoring outcomes shall be reviewed quarterly during IT governance meetings to identify improvement opportunities and strengthen security controls.
- 7.7 Service Continuity and Recovery
- 7.7.1 Integration services shall be incorporated into the Business Continuity Plan (BCP) to ensure uninterrupted data exchange in the event of service disruption.
- 7.7.2 Semi-annual simulation exercises shall be conducted to measure the platform's ability to restore connectivity within the target Recovery Time Objective (RTO).
- 7.7.3 Updated backup copies of integration configurations and access keys shall be stored in a secure encrypted repository.
- 7.7.4 If any critical connectivity test fails, the IT Department shall issue a corrective report detailing the root cause, actions taken, and expected resolution timeline.

8. Policy Responsibility

8.1 Information Technology Department:

8.1.1 Responsible for ensuring the implementation of all controls stipulated in this policy across all active integrations.

8.1.2 Responsible for reviewing technical documentation and security test results prior to go-live.

8.2 Quality and Development Department:

8.2.1 Responsible for verifying policy implementation through periodic audit and review activities.

9. Related Circulars and Instructions

9.1 National Cybersecurity Authority (NCA) — Essential Cybersecurity Controls (ECC).

9.2 Saudi Data & AI Authority (SDAIA) — Personal Data Protection Law (PDPL).

9.3 Insurance Authority — Cybersecurity and Business Continuity instructions applicable to the insurance sector.

10. Policy Retention

10.1 The approved non-editable electronic version shall be retained in the HR system and made accessible to relevant departments.

10.2 The approved hard copy shall be retained by the Quality and Development Department in accordance with the document retention period defined in the Document Retention Schedule.

11. Policy Violation

11.1 Any violation of this policy shall be subject to the penalties stipulated in Diamond Insurance Brokers' approved Disciplinary and Sanctions Policy.

إدارة الجودة والتطوير
Quality & Development Management